

W12D1 – Vulnerability Assessment con Nessus su Metasploitable

Studente: Riccardo Luzzi

Corso: Cyber Security

Sistema utilizzato: Kali Linux

Strumenti utilizzati: Nessus Essentials, Nmap, Netcat, smbclient, showmount, hexdump/strings, VirtualBox, pfSense

Target: Metasploitable – 192.168.51.101

Scenario di rete: Kali/Nessus e Metasploitable su reti differenti, con instradamento tramite pfSense

Introduzione

L'esercitazione W12D1 richiedeva di eseguire un Vulnerability Assessment con Nessus sulla macchina Metasploitable, concentrandosi sui servizi più comuni e analizzando con attenzione i finding restituiti dallo scanner. Per rendere la prova più realistica ho mantenuto Metasploitable su una rete differente rispetto alla macchina di analisi, facendo passare il traffico attraverso pfSense. In questo modo ho verificato che Nessus riuscisse a individuare servizi e vulnerabilità anche attraverso due segmenti di rete distinti.

Dopo la Basic Network Scan ho analizzato prima le vulnerabilità Critical e successivamente le principali High. Per i finding più significativi ho affiancato a Nessus una verifica manuale con Nmap o con strumenti specifici. Per ogni vulnerabilità approfondita ho inoltre indicato una possibile soluzione, in modo da collegare il rischio rilevato a un intervento concreto di remediation. L'obiettivo non era soltanto leggere il report dello scanner, ma capire quale servizio fosse coinvolto, quale fosse il rischio effettivo e come si potrebbe intervenire in un sistema reale.

1. Avvio della scansione e panoramica dei risultati

Ho creato una nuova Basic Network Scan verso 192.168.51.101. La scansione si è conclusa correttamente in circa 17 minuti. Nessus ha riconosciuto un sistema Linux basato su Ubuntu 8.04 e ha prodotto 86 finding raggruppati, con una presenza rilevante di vulnerabilità Critical e High.

Figura 1 – Elenco delle scansioni Nessus eseguite

My Scans

Import

New Folder

New Scan

Search Scans

3 Scans

☐	Name	Scan Type	Schedule	Last Scanned	
☐	vulnerability	Vulnerability	On Demand	Today at 12:50 PM	✗
☐	Primo scan	Host Discovery	On Demand	September 25 at 2:42 ...	✗
☐	Scan base	Vulnerability	On Demand	September 25 at 2:36 ...	✗

Figura 2 – Riepilogo della scansione sul target 192.168.51.101

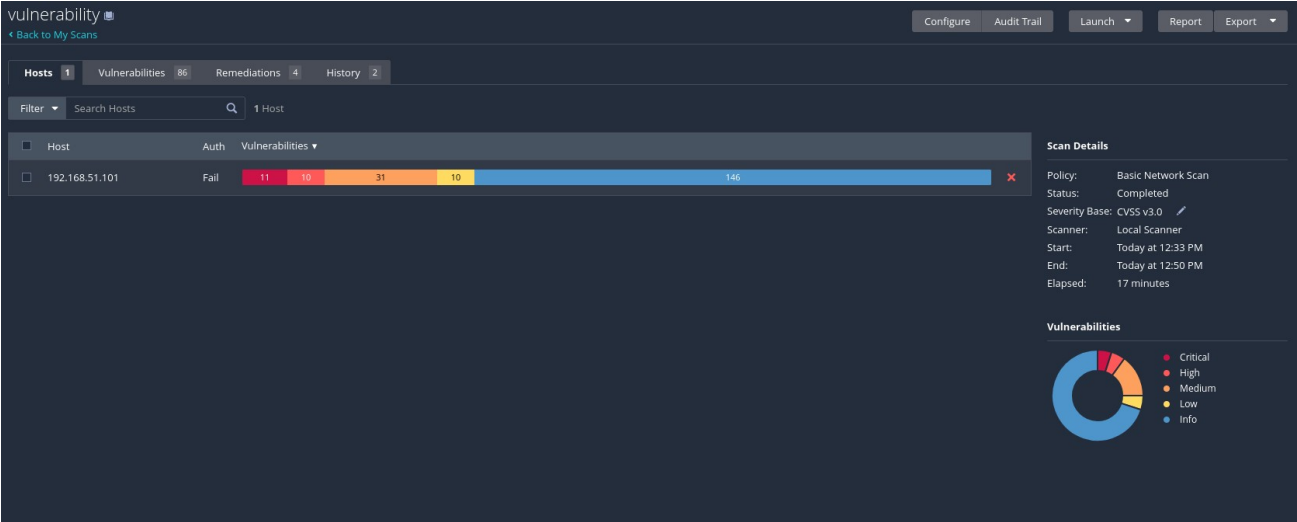


Figura 3 – Prime vulnerabilità ordinate per severità

Filter

Search Vulnerabilities

86 Vulnerabilities

☐	Sev	CVSS	VPR	EPSS	Name	Family	Count	
☐	CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	Plugin ID: 61708
☐	CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1	
☐	CRITICAL	9.8	7.9	0.9927	Apache Tomcat AJP Connector Request Injection (GHOSTCAT)	Web Servers	1	
☐	CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
☐	CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1	
☐	MIXED	...	...	...	Phpmyadmin (Multiple Issues)	CGI abuses	4	
☐	CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
☐	MIXED	...	...	...	PHP (Multiple Issues)	CGI abuses	3	
☐	HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1	
☐	HIGH	7.5 *	4.9	0.119	rlogin Service Detection	Service detection	1	
☐	HIGH	7.5 *	4.9	0.119	rsh Service Detection	Service detection	1	
☐	HIGH	7.5			NFS Shares World Readable	RPC	1	
☐	MIXED	...	...	...	SSL (Multiple Issues)	General	28	
☐	MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	

Host Details

IP:

192.168.51.101

OS:

Linux Kernel 2.6 on Ubuntu 8.04 (hardy)

Start:

Today at 12:33 PM

End:

Today at 12:50 PM

Elapsed:

17 minutes

KB:

Download

Auth:

Fail

Vulnerabilities

Critical

High

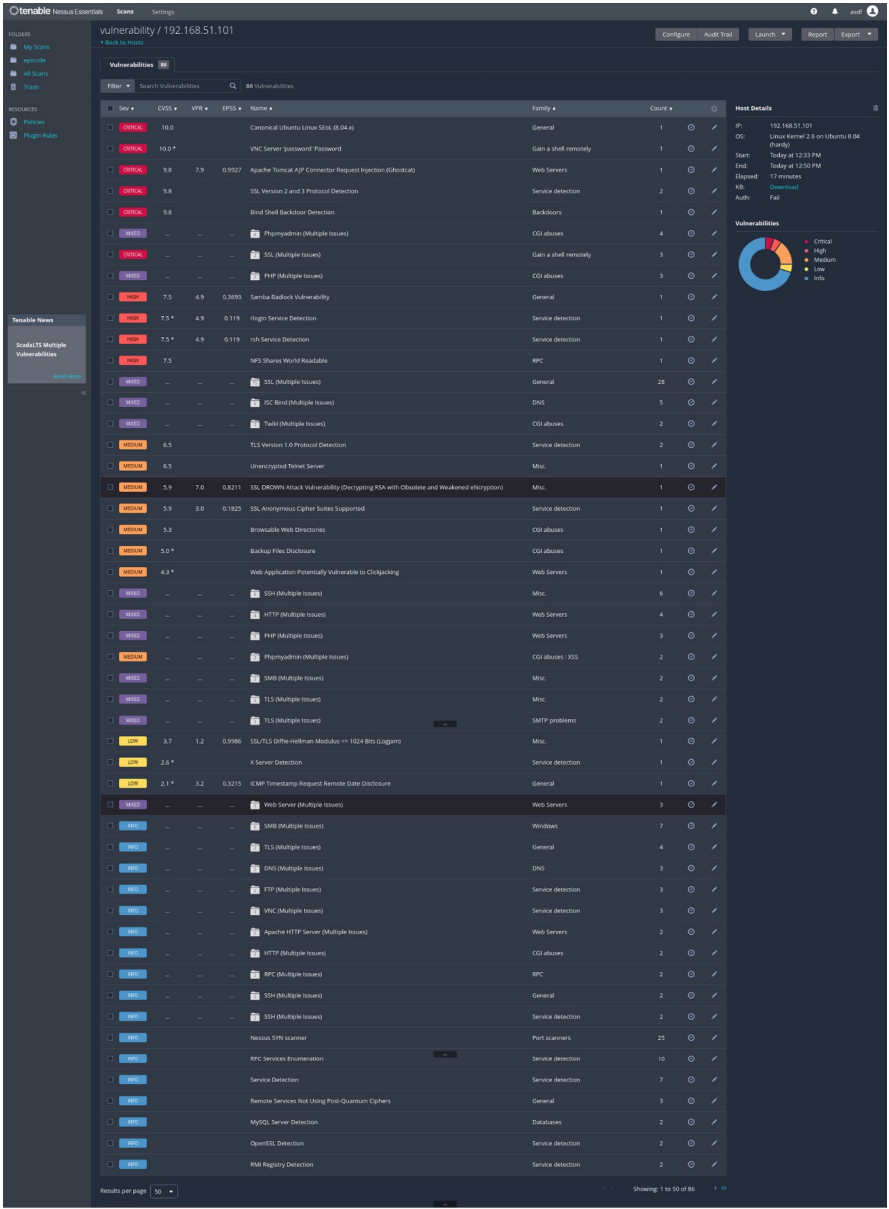
Medium

Low

Info

L’elenco completo evidenzia diversi servizi legacy tipici di Metasploitable. Ho deciso di partire dalle vulnerabilità Critical singole, poi dai finding Critical raggruppati e infine dalle High più significative. Questa scelta mi ha permesso di approfondire prima i problemi con impatto maggiore, mantenendo comunque una visione complessiva del report.

Figura 4 – Elenco completo dei finding del target



2. Vulnerabilità Critical

2.1 Canonical Ubuntu Linux SEoL (8.04.x)

Nessus ha identificato Ubuntu Linux 8.04, sistema ormai fuori dal ciclo di supporto di sicurezza. Il plugin indica come Security End of Life il 9 maggio 2013. Il problema non è la porta 80 in sé: quella porta è il punto dal quale lo scanner ha raccolto informazioni utili al riconoscimento. Il rischio reale è l'uso di un sistema operativo non più mantenuto, che non riceve patch di sicurezza.

Il rischio principale è mantenere in produzione un sistema che non riceve più patch di sicurezza e che può dipendere da componenti applicativi altrettanto obsoleti.

Possibile soluzione: migrare i servizi verso una versione di Ubuntu ancora supportata e sostituire il sistema operativo obsoleto. Prima della migrazione andrebbero verificati dipendenze e applicativi installati, così da evitare incompatibilità e mantenere aggiornabile l'intero ambiente.

Figura 5 – Nessus: Ubuntu 8.04 fuori supporto

vulnerability / Plugin #201352

Configure Audit Trail Launch Report Export

Vulnerabilities 86

CRITICAL Canonical Ubuntu Linux SEoL (8.04.x)

Description
According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

Solution
Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

See Also
<http://www.nessus.org/u73bdb2d2e>

Output

```
OS : Ubuntu Linux 8.04
Security End of Life : May 9, 2013
Time since Security End of Life (Est.) : >= 13 years
```

To see debug logs, please visit individual host

Port	Hosts
80 / tcp / www	192.168.51.101

Plugin Details

Severity: Critical
ID: 201352
Version: 1.2
Type: combined
Family: General
Published: July 3, 2024
Modified: March 26, 2025

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 10.0
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

CPE: cpe/o:canonical:ubuntu_linux
Unsupported by vendor: true

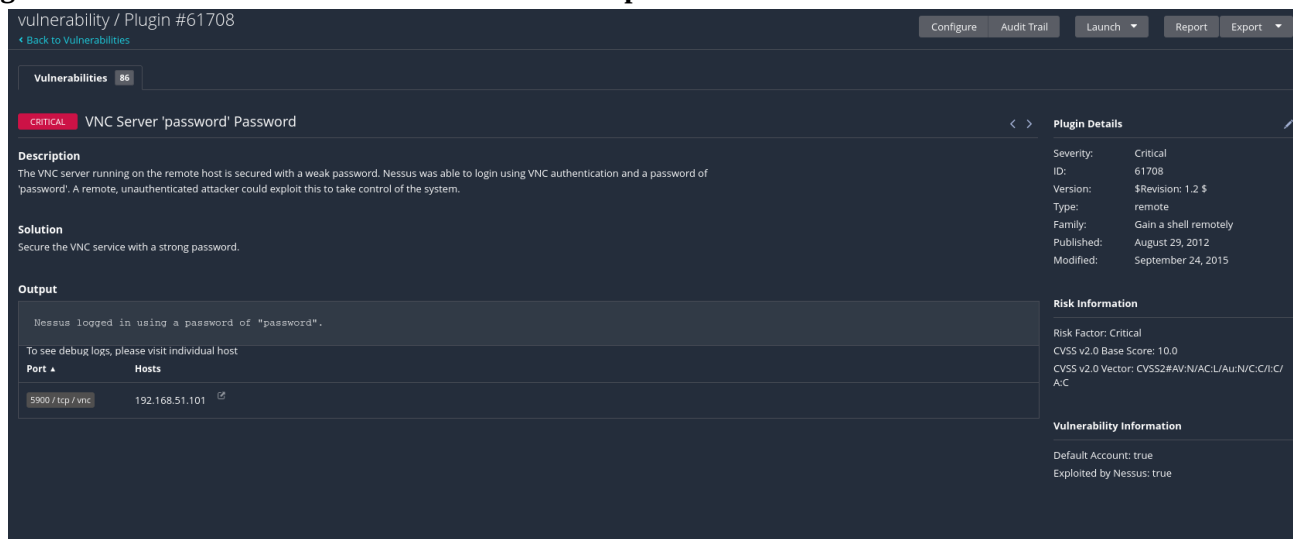
2.2 VNC Server con password debole

Il servizio VNC sulla porta 5900/TCP utilizza la password “password”. Il Plugin Output è particolarmente significativo perché Nessus dichiara di essere riuscito ad autenticarsi. Questo rende il finding una verifica concreta e non un semplice controllo basato sulla versione del software.

L'impatto è un possibile accesso remoto non autorizzato all'ambiente grafico della macchina, con possibilità di operare sul sistema con i privilegi dell'utente collegato.

Possibile soluzione: sostituire immediatamente la password debole con una credenziale robusta, limitare tramite firewall gli host autorizzati a raggiungere la porta 5900/TCP e disabilitare il servizio VNC se non è necessario.

Figura 6 – Nessus: autenticazione VNC riuscita con password debole



The screenshot shows the Nessus interface for a vulnerability report titled "vulnerability / Plugin #61708". The report is categorized as "CRITICAL" and is titled "VNC Server 'password' Password". The description states: "The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system." The solution is to "Secure the VNC service with a strong password." The output shows "Nessus logged in using a password of 'password'." The plugin details include: Severity: Critical, ID: 61708, Version: \$Revision: 1.2 \$, Type: remote, Family: Gain a shell remotely, Published: August 29, 2012, Modified: September 24, 2015. The risk information shows a Risk Factor: Critical, CVSS v2.0 Base Score: 10.0, and CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C. The vulnerability information shows Default Account: true and Exploited by Nessus: true.

Per confermare manualmente la presenza del servizio ho eseguito `nmap -sV -p 5900`. Nmap ha rilevato la porta aperta e il protocollo VNC 3.3. La verifica Nmap conferma il servizio; la prova della password debole rimane invece quella prodotta da Nessus.

Figura 7 – Verifica Nmap del servizio VNC sulla porta 5900/TCP

```
Session Actions Edit View Help
(kali@kali)-[~]
└─$ nmap -sV -p 5900 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-29 13:08 -0400
Nmap scan report for 192.168.51.101
Host is up (0.0021s latency).

PORT      STATE SERVICE VERSION
5900/tcp  open  vnc      VNC (protocol 3.3)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.02 seconds
└─$
```

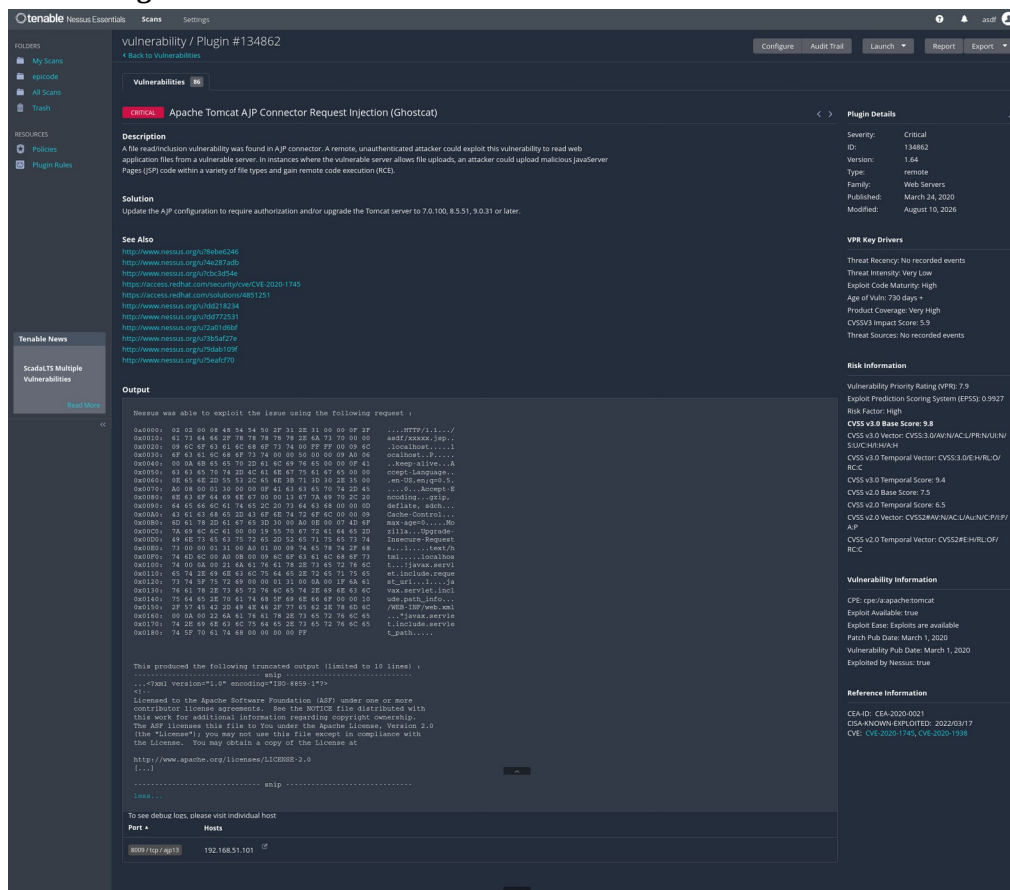
2.3 Apache Tomcat AJP Request Injection – Ghostcat

Nessus ha rilevato la vulnerabilità Ghostcat sul connettore AJP di Apache Tomcat, porta 8009/TCP. Il finding è associato a CVE-2020-1938 e riporta CVSS 9.8. Il Plugin Output specifica che Nessus è riuscito a sfruttare il problema mediante una richiesta AJP appositamente costruita.

La vulnerabilità può consentire la lettura di file interni dell'applicazione web; in determinate configurazioni può arrivare anche all'esecuzione di codice.

Possibile soluzione: aggiornare Apache Tomcat a una versione corretta e supportata, proteggere il connettore AJP limitandone l'accesso ai soli host necessari e configurare l'autenticazione prevista. Se AJP non viene utilizzato, la scelta più sicura è disabilitarlo.

Figura 8 – Nessus: dettaglio della vulnerabilità Ghostcat



Per capire meglio il contenuto esadecimale riportato da Nessus ho copiato i byte in un file ghostcat.hex e li ho trasformati in binario con `xxd -r -p`. Con `strings` ho potuto leggere le parti testuali presenti nella richiesta, tra cui `/WEB-INF/web.xml` e diversi attributi `javax.servlet.include.*`. Questo mostra in modo molto concreto come la richiesta tenti di raggiungere una risorsa interna dell'applicazione.

Figura 9 – Preparazione del file esadecimale ghostcat.hex

```

Session Actions Edit View Help
GNU nano 9.2
02 02 00 08 48 54 54 50 2F 31 2E 31 00 00 0F 2F
61 73 64 66 2F 78 78 78 78 78 2E 6A 73 70 00 00
09 6C 6F 63 61 6C 68 6F 73 74 00 FF FF 00 09 6C
6F 63 61 6C 68 6F 73 74 00 00 50 00 00 09 A0 06
00 0A 6B 65 65 70 2D 61 6C 69 76 65 00 00 0F 41
63 63 65 70 74 2D 4C 61 6E 67 75 61 67 65 00 00
0E 65 6E 2D 55 53 2C 65 6E 3B 71 3D 30 2E 35 00
A0 08 00 01 30 00 00 0F 41 63 63 65 70 74 2D 45
6E 63 6F 64 69 6E 67 00 00 13 67 7A 69 70 2C 20
64 65 66 6C 61 74 65 2C 20 73 64 63 68 00 00 0D
43 61 63 68 65 2D 43 6F 6E 74 72 6F 6C 00 00 09
6D 61 78 2D 61 67 65 3D 30 00 A0 0E 00 07 4D 6F
7A 69 6C 6C 61 00 00 19 55 70 67 72 61 64 65 2D
49 6E 73 65 63 75 72 65 2D 52 65 71 75 65 73 74
73 00 00 01 31 00 A0 01 00 09 74 65 78 74 2F 68
74 6D 6C 00 A0 0B 00 09 6C 6F 63 61 6C 68 6F 73
74 00 0A 00 21 6A 61 76 61 78 2E 73 65 72 76 6C
65 74 2E 69 6E 63 6C 75 64 65 2E 72 65 71 75 65
73 74 5F 75 72 69 00 00 01 31 00 0A 00 1F 6A 61
76 61 78 2E 73 65 72 76 6C 65 74 2E 69 6E 63 6C
75 64 65 2E 70 61 74 68 5F 69 6E 66 6F 00 00 10
2F 57 45 42 2D 49 4E 46 2F 77 65 62 2E 78 6D 6C
00 0A 00 22 6A 61 76 61 78 2E 73 65 72 76 6C 65
74 2E 69 6E 63 6C 75 64 65 2E 73 65 72 76 6C 65
74 5F 70 61 74 68 00 00 00 00 FF 00 00 00 00 00
23 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
23 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
24 74 2E 69 6E 63 6C 75 64 65 2E 73 65 72 76 6C 65
25 74 5F 70 61 74 68 00 00 00 00 FF 00 00 00 00 00

```

Figura 10 – Estrazione delle stringhe leggibili dal payload AJP

```

(kali@kali)-[~]
$ nano ghostcat.hex
(kali@kali)-[~]
$ xxd -r -p ghostcat.hex > ghostcat.bin
(kali@kali)-[~]
$ strings -a ghostcat.bin
HTTP/1.1
/asdf/xxxxx.jsp
localhost
localhost
keep-alive
Accept-Language
en-US,en;q=0.5
Accept-Encoding
gzip, deflate, sdch
Cache-Control
max-age=0
Mozilla
Upgrade-Insecure-Requests
text/html
localhost
!javax.servlet.include.request_uri
javax.servlet.include.path_info
/WEB-INF/web.xml
"javax.servlet.include.servlet_path
(kali@kali)-[~]
$

```

Figura 11 – Visualizzazione esadecimale e ASCII con hexdump -C

```
(kali@kali)-[~]
$ hexdump -C ghostcat.bin
00000000  02 02 00 08 48 54 54 50  2f 31 2e 31 00 00 0f 2f  |....HTTP/1.1 .../|
00000010  61 73 64 66 2f 78 78 78  78 78 2e 6a 73 70 00 00  |asdf/xxxxx.jsp..|
00000020  09 6c 6f 63 61 6c 68 6f  73 74 00 ff ff 00 09 6c  |.localhost.....l|
00000030  6f 63 61 6c 68 6f 73 74  00 00 50 00 00 09 a0 06  |localhost..P.....|
00000040  00 0a 6b 65 65 70 2d 61  6c 69 76 65 00 00 0f 41  |..keep-alive ...A|
00000050  63 63 65 70 74 2d 4c 61  6e 67 75 61 67 65 00 00  |ccept-Language..|
00000060  0e 65 6e 2d 55 53 2c 65  6e 3b 71 3d 30 2e 35 00  |.en-US,en;q=0.5.|
00000070  a0 08 00 01 30 00 00 0f  41 63 63 65 70 74 2d 45  |....0 ... Accept-E|
00000080  6e 63 6f 64 69 6e 67 00  00 13 67 7a 69 70 2c 20  |ncoding ... gzip, |
00000090  64 65 66 6c 61 74 65 2c  20 73 64 63 68 00 00 0d  |deflate, sdch ...|
000000a0  43 61 63 68 65 2d 43 6f  6e 74 72 6f 6c 00 00 09  |Cache-Control ...|
000000b0  6d 61 78 2d 61 67 65 3d  30 00 a0 0e 00 07 4d 6f  |max-age=0....Mo|
000000c0  7a 69 6c 6c 61 00 00 19  55 70 67 72 61 64 65 2d  |zilla ... Upgrade-|
000000d0  49 6e 73 65 63 75 72 65  2d 52 65 71 75 65 73 74  |Insecure-Request|
000000e0  73 00 00 01 31 00 a0 01  00 09 74 65 78 74 2f 68  |s ...1.....text/h|
000000f0  74 6d 6c 00 a0 0b 00 09  6c 6f 63 61 6c 68 6f 73  |tml.....localhos|
00000100  74 00 0a 00 21 6a 61 76  61 78 2e 73 65 72 76 6c  |t ...!javax.servl|
00000110  65 74 2e 69 6e 63 6c 75  64 65 2e 72 65 71 75 65  |et.include.reque|
00000120  73 74 5f 75 72 69 00 00  01 31 00 0a 00 1f 6a 61  |st_uri ...1....ja|
00000130  76 61 78 2e 73 65 72 76  6c 65 74 2e 69 6e 63 6c  |vax.servlet.incl|
00000140  75 64 65 2e 70 61 74 68  5f 69 6e 66 6f 00 00 10  |lude.path_info ...|
00000150  2f 57 45 42 2d 49 4e 46  2f 77 65 62 2e 78 6d 6c  |/WEB-INF/web.xml|
00000160  00 0a 00 22 6a 61 76 61  78 2e 73 65 72 76 6c 65  | ... "javax.servle|
00000170  74 2e 69 6e 63 6c 75 64  65 2e 73 65 72 76 6c 65  |t.include.servle|
00000180  74 5f 70 61 74 68 00 00  00 00 ff                                |t_path.....|
0000018b
```

2.4 SSL Version 2 and 3 Protocol Detection

Nessus ha rilevato il supporto di protocolli SSL obsoleti su due servizi: SMTP sulla porta 25/TCP e PostgreSQL sulla porta 5432/TCP. L'output mostra numerose cipher suite legacy e assegna al finding severit  Critical con CVSS 9.8. Protocolli e cifrari di questo tipo non dovrebbero essere utilizzati perch  espongono le comunicazioni a debolezze crittografiche note.

Figura 12 – Nessus: rilevamento di SSLv2/SSLv3 e cipher deboli

[illegible]

La verifica con ssl-enum-ciphers su PostgreSQL ha confermato il supporto di SSLv3 e TLS 1.0 con cipher valutate F. Nmap segnala inoltre 3DES/DES vulnerabili a SWEET32, RC4 deprecato, CBC in SSLv3, SHA1 e altri algoritmi obsoleti. La stessa situazione è stata osservata anche sul servizio SMTP.

Possibile soluzione: disabilitare SSLv2/SSLv3 e TLS 1.0 sui servizi interessati e rimuovere le cipher suite obsolete. I servizi dovrebbero essere configurati per usare soltanto versioni TLS e algoritmi crittografici moderni compatibili con il software in uso.

Figura 13 – Nmap ssl-enum-ciphers sulla porta PostgreSQL 5432/TCP

```
(kali@kali)-[~]
$ nmap -sV -p 5432 --script ssl-enum-ciphers 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-29 13:28 -0400
Nmap scan report for 192.168.51.101
Host is up (0.0015s latency).

PORT      STATE SERVICE
5432/tcp  open  postgresql

ssl-enum-ciphers:
  SSLv3:
    ciphers:
      TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA (dh 1024) - F
      TLS_DHE_RSA_WITH_AES_128_CBC_SHA (dh 1024) - F
      TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 1024) - F
      TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 1024) - F
      TLS_RSA_WITH_AES_128_CBC_SHA (rsa 1024) - F
      TLS_RSA_WITH_AES_256_CBC_SHA (rsa 1024) - F
      TLS_RSA_WITH_RC4_128_SHA (rsa 1024) - F
    compressors:
      DEFLATE
      NULL
    cipher preference: client
    warnings:
      64-bit block cipher 3DES vulnerable to SWEET32 attack
      Broken cipher RC4 is deprecated by RFC 7465
      CBC-mode cipher in SSLv3 (CVE-2014-3566)
      Insecure certificate signature (SHA1), score capped at F
  TLSv1.0:
    ciphers:
      TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA (dh 1024) - F
      TLS_DHE_RSA_WITH_AES_128_CBC_SHA (dh 1024) - F
      TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 1024) - F
      TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 1024) - F
      TLS_RSA_WITH_AES_128_CBC_SHA (rsa 1024) - F
      TLS_RSA_WITH_AES_256_CBC_SHA (rsa 1024) - F
      TLS_RSA_WITH_RC4_128_SHA (rsa 1024) - F
    compressors:
      DEFLATE
      NULL
    cipher preference: client
    warnings:
      64-bit block cipher 3DES vulnerable to SWEET32 attack
      Broken cipher RC4 is deprecated by RFC 7465
      Insecure certificate signature (SHA1), score capped at F
  _ least strength: F

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.93 seconds
```

2.5 Bind Shell Backdoor Detection

Questo finding è uno dei più gravi dell'intera scansione. Nessus ha individuato una bind shell sulla porta 1524/TCP e ha eseguito il comando id senza autenticazione. L'output restituisce uid=0(root), gid=0(root), quindi la shell è disponibile direttamente con privilegi amministrativi completi.

Figura 14 – Nessus: bind shell accessibile come root

The screenshot shows the Nessus interface for a vulnerability titled "Bind Shell Backdoor Detection" (Plugin #51988). The severity is "Critical". The description states: "A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly." The solution suggests verifying if the remote host has been compromised and reinstalling the system if necessary. The output shows a truncated command execution: "Nessus was able to execute the command 'id' using the following request: ... This produced the following truncated output (limited to 10 lines): ... root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root) root@metasploitable:/#". The risk information section includes a CVSS v3.0 Base Score of 9.8 and a CVSS v2.0 Base Score of 10.0. At the bottom, a table lists the host 192.168.51.101 on port 1524/tcp as a "bindshell" service.

Port	Hosts
1524/tcp/wild_shell	192.168.51.101

Ho verificato il risultato con Nmap e Netcat. Nmap identifica il servizio come "Metasploitable root shell"; collegandomi con nc 192.168.51.101 1524 ho ottenuto direttamente il prompt root e il comando id ha confermato uid=0(root).

Possibile soluzione: rimuovere immediatamente la bind shell e identificare il processo o la configurazione che la avvia. In un sistema reale la macchina dovrebbe essere considerata compromessa: sarebbe necessario eseguire un'analisi di incident response e, se non fosse possibile garantire l'integrità del sistema, procedere con una reinstallazione da una fonte affidabile.

Figura 15 – Nmap identifica la root shell sulla porta 1524/TCP

```
(kali㉿kali)-[~]
$ nmap -sV -p 1524 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-29 13:31 -0400
Nmap scan report for 192.168.51.101
Host is up (0.00098s latency).

PORT      STATE SERVICE      VERSION
1524/tcp  open  bindshell    Metasploitable root shell

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.77 seconds
```

Figura 16 – Accesso manuale alla bind shell tramite Netcat

```
(kali㉿kali)-[~]
$ nc 192.168.51.101 1524
root@metasploitable:/# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/#
```

2.6 Debian OpenSSH/OpenSSL Random Number Generator Weakness

Nel gruppo SSL (Multiple Issues) Nessus ha riportato due finding Critical collegati alla storica debolezza del generatore di numeri casuali presente in vecchie versioni Debian/Ubuntu. Uno riguarda i certificati SSL usati da SMTP e PostgreSQL, mentre l'altro riguarda la chiave host SSH sulla porta 22/TCP. La ridotta entropia utilizzata durante la generazione può rendere prevedibile il materiale crittografico.

Figura 17 – Gruppo Critical SSL (Multiple Issues)

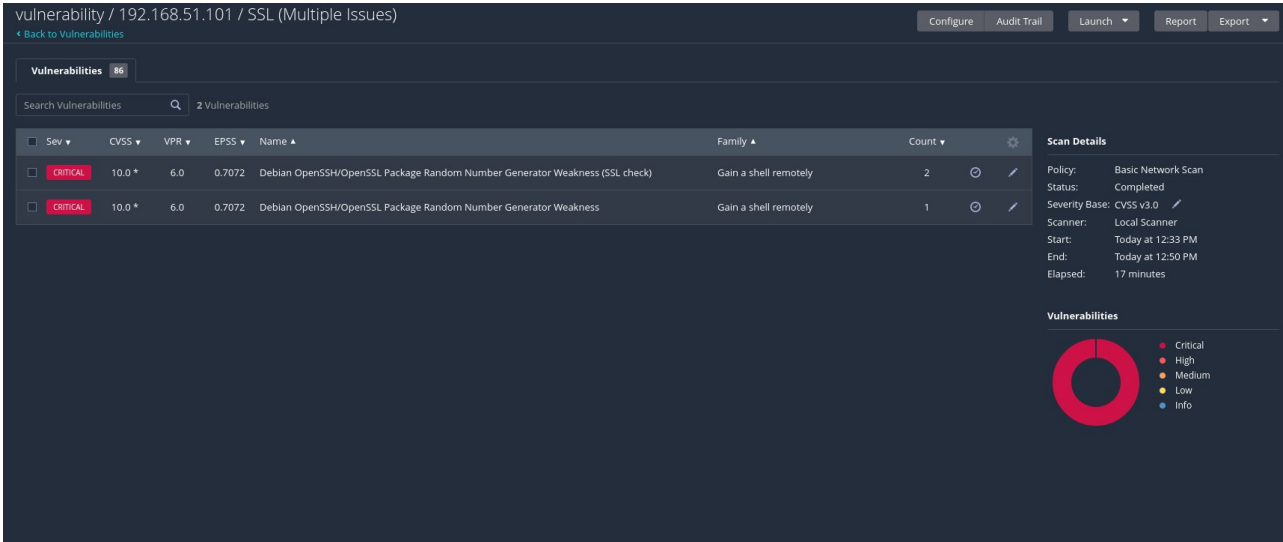


Figura 18 – Nessus: debolezza RNG Debian/OpenSSL sui servizi SSL

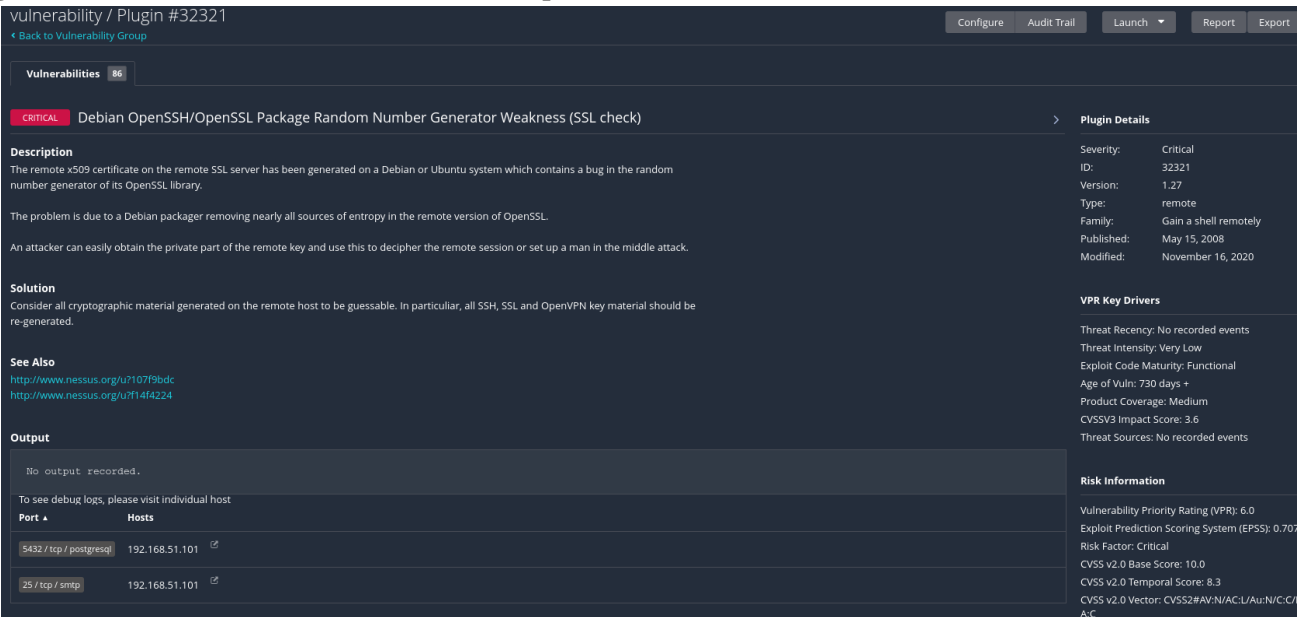


Figura 19 – Nessus: debolezza RNG Debian/OpenSSL sulla chiave SSH

Vulnerability / Plugin #32314

Back to Vulnerability Group

Vulnerabilities 86

CRITICAL

Debian OpenSSH/OpenSSL Package Random Number Generator Weakness

Description

The remote SSH host key has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.

The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.

An attacker can easily obtain the private part of the remote key and use this to set up decipher the remote session or set up a man in the middle attack.

Solution

Consider all cryptographic material generated on the remote host to be guessable. In particular, all SSH, SSL and OpenVPN key material should be re-generated.

See Also

<http://www.nessus.org/u/107f9bdc>
<http://www.nessus.org/u/f14f4224>

Output

No output recorded.

To see debug logs, please visit individual host

Port	Hosts
22/tcp/ssh	192.168.51.101

Plugin Details

Severity: Critical
ID: 32314
Version: 1.21
Type: remote
Family: Gain a shell remotely
Published: May 14, 2008
Modified: July 24, 2024

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: Functional
Age of Vuln: 730 days +
Product Coverage: Medium
CVSSv2 Impact Score: 3.6
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 6.0
Exploit Prediction Scoring System (EPSS): 0.7072
Risk Factor: Critical
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Temporal Score: 8.3
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:N

La verifica Nmap ha confermato OpenSSH 4.7p1 Debian 8ubuntu1 sulla porta 22, Postfix sulla 25 e PostgreSQL 8.3.x sulla 5432. Con ssh-keyscan ho inoltre recuperato la chiave pubblica RSA dell'host. Questi comandi confermano i servizi e il materiale crittografico esposto; l'identificazione specifica della chiave come debole deriva dal plugin Nessus.

Possibile soluzione: aggiornare OpenSSL/OpenSSH a versioni corrette e rigenerare tutto il materiale crittografico creato con la versione vulnerabile, comprese le chiavi host SSH e i certificati SSL/TLS. Le vecchie chiavi dovrebbero essere revocate o rimosse.

Figura 20 – Version detection dei servizi 22, 25 e 5432/TCP

```
(kali㉿kali)-[~]
$ nmap -sV -p 22,52,5432 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-29 13:40 -0400
Nmap scan report for 192.168.51.101
Host is up (0.0012s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
52/tcp    closed xns-time
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.75 seconds
```

Figura 21 – Recupero della chiave pubblica SSH con ssh-keyscan

```
[kali@kali] ~$ ssh-keygen -t rsa -b 4096 -f ~/.ssh/id_rsa -C kali@kali -q
```

3. Vulnerabilità High

3.1 Samba Badlock Vulnerability

Nessus segnala che la patch relativa a Badlock (CVE-2016-2118) non è applicata al servizio Samba sulla porta 445/TCP. Il problema riguarda la negoziazione del livello di autenticazione nei protocolli RPC e può favorire attacchi man-in-the-middle e downgrade della protezione.

Figura 22 – Nessus: Samba Badlock Vulnerability

vulnerability / Plugin #90509

Configure Audit Trail Launch Report Export

Vulnerabilities 86

HIGH Samba Badlock Vulnerability

Description

The version of Samba, a CIFS/SMB server for Linux and Unix, running on the remote host is affected by a flaw, known as Badlock, that exists in the Security Account Manager (SAM) and Local Security Authority (Domain Policy) (LSAD) protocols due to improper authentication level negotiation over Remote Procedure Call (RPC) channels. A man-in-the-middle attacker who is able to intercept the traffic between a client and a server hosting a SAM database can exploit this flaw to force a downgrade of the authentication level, which allows the execution of arbitrary Samba network calls in the context of the intercepted user, such as viewing or modifying sensitive security data in the Active Directory (AD) database or disabling critical services.

Solution

Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.

See Also

<https://www.samba.org/samba/security/CVE-2016-2118.html>

Output

Nessus detected that the Samba Badlock patch has not been applied.

To see debug logs, please visit individual host

Port Hosts

445 / tcp / cifs 192.168.51.101

Severity: High

ID: 90509

Version: 1.5

Type: remote

Family: General

Published: April 13, 2016

Modified: November 17, 2025

VPR Key Drivers

Threat Recency: No recorded events

Threat Intensity: Very Low

Exploit Code Maturity: Unproven

Age of Vuln: 730 days +

Product Coverage: Very High

CVSSv3 Impact Score: 5.9

Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 4.9

Exploit Prediction Scoring System (EPSS): 0.3693

Risk Factor: Medium

CVSS v3.0 Base Score: 7.5

CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H

CVSS v3.0 Temporal Vector: CVSS:3.0/E:U/RL:O/RC:C

Le verifiche manuali mostrano un server Samba molto datato. Nmap rileva Samba smbd sulle porte 139 e 445; lo script smb-protocols evidenzia SMBv1, classificato come pericoloso; infine smbclient consente un login anonimo ed enumera le share print\$, tmp, opt, IPC\$ e ADMIN\$. Questi controlli non dimostrano da soli Badlock, ma confermano un servizio Samba legacy e una configurazione permissiva.

Possibile soluzione: aggiornare Samba a una versione corretta e supportata, applicando la patch relativa a Badlock. È inoltre opportuno disabilitare SMBv1, eliminare l'accesso anonimo non necessario e limitare le condivisioni ai soli utenti e host autorizzati.

Figura 23 – Nmap: Samba sulle porte 139 e 445/TCP

```
(kali@kali)-[~]
$ nmap -sV -p 139,445 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-29 13:45 -0400
Nmap scan report for 192.168.51.101
Host is up (0.00090s latency).

PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.76 seconds
```

Figura 24 – Nmap smb-protocols: SMBv1 attivo

```
(kali@kali)-[~]
$ nmap -p 445 --script smb-protocols,smb2-security-mode 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-29 13:47 -0400
Nmap scan report for 192.168.51.101
Host is up (0.0012s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb-protocols:
|   dialects:
|_    NT LM 0.12 (SMBv1) [dangerous, but default]

Nmap done: 1 IP address (1 host up) scanned in 0.96 seconds
```


Figura 27 – Nessus: rsh Service Detection

vulnerability / Plugin #10245

ConfigureAudit TrailLaunchReportExport

Vulnerabilities 86

HIGH

rsh Service Detection

Description

The rsh service is running on the remote host. This service is vulnerable since data is passed between the rsh client and server in cleartext. A man-in-the-middle attacker can exploit this to sniff logins and passwords. Also, it may allow poorly authenticated logins without passwords. If the host is vulnerable to TCP sequence number guessing (from any network) or IP spoofing (including ARP hijacking on a local network) then it may be possible to bypass authentication.

Finally, rsh is an easy way to turn file-write access into full logins through the .rhosts or rhosts.equiv files.

Solution

Comment out the 'rsh' line in /etc/inetd.conf and restart the inetd process. Alternatively, disable this service and use SSH instead.

Output

No output recorded.

To see debug logs, please visit individual host

Port	Hosts
514/tcp/rsh	192.168.51.101

Plugin Details

Severity: High

ID: 10245

Version: 1.38

Type: remote

Family: Service detection

Published: August 22, 1999

Modified: April 11, 2022

VPR Key Drivers

Threat Recency: No recorded events

Threat Intensity: Very Low

Exploit Code Maturity: Unproven

Age of Vuln: 730 days +

Product Coverage: Low

CVSSv3 Impact Score: 5.9

Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 4.9

Exploit Prediction Scoring System (EPSS): 0.119

Risk Factor: High

CVSS v2.0 Base Score: 7.5

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P

Con Nmap entrambe le porte risultano aperte. La 513 viene riconosciuta come login?, mentre la 514 viene indicata come tcpwrapped. Il controllo con -sC -sV non aggiunge ulteriori dettagli. Per questo l'identificazione precisa di rsh deriva dal finding Nessus, mentre Nmap conferma soprattutto l'esposizione delle porte.

Possibile soluzione: disabilitare i servizi rlogin e rsh e sostituirli con SSH, che protegge autenticazione e traffico tramite cifratura. Dovrebbero inoltre essere eliminate eventuali configurazioni di trust non necessarie basate su .rhosts o hosts.equiv.

Figura 28 – Nmap -sV sulle porte 513 e 514/TCP

```
(kali@kali)-[~]
└─$ nmap -sV -p 513,514 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-29 13:57 -0400
Nmap scan report for 192.168.51.101
Host is up (0.00064s latency).

PORT      STATE SERVICE      VERSION
513/tcp   open  login?
514/tcp   open  tcpwrapped

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.88 seconds
```

Figura 29 – Nmap -sC -sV sulle porte rlogin/rsh

```
(kali@kali)-[~]
└─$ nmap -sC -sV -p 513,514 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-29 13:58 -0400
Nmap scan report for 192.168.51.101
Host is up (0.00076s latency).

PORT      STATE SERVICE      VERSION
513/tcp   open  login?
514/tcp   open  tcpwrapped

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.07 seconds
```

3.3 NFS Shares World Readable

Nessus ha rilevato che il server NFS esporta la directory radice / senza restrizioni specifiche sugli host autorizzati. Nel Plugin Output compare infatti “/ *”. Una configurazione di questo tipo può esporre a sistemi remoti file e directory che non dovrebbero essere accessibili.

Figura 30 – Nessus: NFS Shares World Readable

The screenshot displays the Nessus interface for a vulnerability report. The title is 'vulnerability / Plugin #42256'. The main finding is 'NFS Shares World Readable' with a severity of 'High'. The description states: 'The remote NFS server is exporting one or more shares without restricting access (based on hostname, IP, or IP range)'. The solution suggests: 'Place the appropriate restrictions on all NFS shares'. The output section shows: 'The following shares have no access restrictions : / *'. The risk information section shows: 'Risk Factor: Medium', 'CVSS v3.0 Base Score: 7.5', and 'CVSS v2.0 Base Score: 5.0'. The vulnerability information section shows: 'Vulnerability Pub Date: January 1, 1985'.

La verifica manuale conferma completamente il finding. `showmount -e` mostra l’export “/ *”; Nmap identifica `rpcbind` sulla porta 111 e NFS sulla 2049; gli script `nfs-showmount` e `nfs-ls` riescono anche a enumerare da remoto il contenuto della root, visualizzando directory come `bin`, `home`, `lib`, `usr` e altre.

Possibile soluzione: modificare `/etc/exports` limitando l’accesso ai soli host o alle sole subnet autorizzate, evitando l’uso di “*”. Andrebbero inoltre concessi soltanto i permessi strettamente necessari e verificata la corretta applicazione delle opzioni di sicurezza NFS.

Figura 31 – showmount: export della root senza restrizioni

```
(kali@kali)-[~]
$ showmount -e 192.168.51.101
Export list for 192.168.51.101:
/ *
```

Figura 32 – Nmap: rpcbind e NFS sulle porte 111 e 2049/TCP

```
(kali@kali)-[~]
$ nmap -sV -p 111,2049 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-29 14:01 -0400
Nmap scan report for 192.168.51.101
Host is up (0.00074s latency).

PORT      STATE SERVICE VERSION
111/tcp    open  rpcbind 2 (RPC #100000)
2049/tcp   open  nfs      2-4 (RPC #100003)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.83 seconds
```

Figura 33 – Nmap nfs-showmount e nfs-ls: enumerazione del filesystem esportato

```
(kali@kali)-[~]
$ nmap -p 111,2049 --script nfs-showmount,nfs-ls 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-29 14:07 -0400
Nmap scan report for 192.168.51.101
Host is up (0.00095s latency).

PORT      STATE SERVICE
111/tcp   open  rpcbind
| nfs-ls: Volume /
|  access: Read Lookup Modify Extend Delete NoExecute
| PERMISSION UID  GID  SIZE  TIME          FILENAME
| drwxr-xr-x  0    0   4096  2012-05-14T03:35:33 bin
| drwxr-xr-x  0    0   4096  2010-04-16T06:16:02 home
| drwxr-xr-x  0    0   4096  2010-03-16T22:57:40 initrd
| lrwxrwxrwx  0    0    32   2010-04-28T20:26:18 initrd.img
| drwxr-xr-x  0    0   4096  2012-05-14T03:35:22 lib
| drwx----- 0    0  16384 2010-03-16T22:55:15 lost+found
| drwxr-xr-x  0    0   4096  2010-03-16T22:55:52 media
| drwxr-xr-x  0    0   4096  2010-04-28T20:16:56 mnt
| drwxr-xr-x  0    0   4096  2012-05-14T01:54:53 sbin
| drwxr-xr-x  0    0   4096  2010-04-28T04:06:37 usr
|_
|_ nfs-showmount:
|_ / *
2049/tcp   open  nfs

Nmap done: 1 IP address (1 host up) scanned in 0.87 seconds
```

4. Riepilogo dei finding approfonditi

Finding	Severità	Porta/e	Verifica manuale
Ubuntu Linux 8.04 End of Life	Critical	80/TCP	Conferma del sistema obsoleto tramite Nessus
VNC Server “password” Password	Critical	5900/TCP	Nmap: VNC protocol 3.3; Nessus effettua il login
Tomcat AJP Ghostcat	Critical	8009/TCP	Analisi manuale del payload AJP e /WEB-INF/web.xml
SSLv3 / protocolli e cipher obsolete	Critical	25, 5432/TCP	ssl-enum-ciphers: SSLv3/TLS1.0, strength F
Bind Shell Backdoor	Critical	1524/TCP	Nmap + Netcat: shell root senza autenticazione
Debian OpenSSL RNG Weakness	Critical	22, 25, 5432/TCP	Nmap version detection + ssh-keyscan
Samba Badlock	High	445/TCP	Samba legacy, SMBv1 e login anonimo
rlogin / rsh	High	513, 514/TCP	Nmap conferma le porte esposte
NFS Shares World Readable	High	111, 2049/TCP	showmount e nfs-ls confermano export / *

5. Comandi principali utilizzati

Comando	Scopo
<code>nmap -sV -p 5900 192.168.51.101</code>	Verifica del servizio VNC
<code>xxd -r -p ghostcat.hex > ghostcat.bin</code>	Conversione del payload Ghostcat da esadecimale a binario
<code>strings -a ghostcat.bin</code>	Estrazione delle stringhe leggibili dal payload AJP
<code>hexdump -C ghostcat.bin</code>	Visualizzazione esadecimale e ASCII del payload
<code>nmap -sV -p 5432 --script ssl-enum-ciphers 192.168.51.101</code>	Analisi delle cipher PostgreSQL
<code>nc 192.168.51.101 1524</code>	Verifica della bind shell
<code>ssh-keyscan 192.168.51.101</code>	Recupero della chiave pubblica SSH
<code>nmap -p 445 --script smb-protocols,smb2-security-mode 192.168.51.101</code>	Verifica dei protocolli SMB
<code>smbclient -L //192.168.51.101 -N</code>	Enumerazione anonima delle share Samba
<code>showmount -e 192.168.51.101</code>	Visualizzazione degli export NFS
<code>nmap -p 111,2049 --script nfs-showmount,nfs-ls 192.168.51.101</code>	Enumerazione NFS

6. Conclusioni

L'esercitazione mi ha permesso di utilizzare Nessus non soltanto come strumento automatico, ma come punto di partenza per verifiche successive. Il risultato più utile è stato confrontare il finding dello scanner con ciò che riuscivo a osservare direttamente dalla macchina Kali. In alcuni casi Nmap ha semplicemente confermato la presenza del servizio; in altri, come la bind shell e l'export NFS, la verifica manuale ha mostrato in modo molto evidente l'impatto pratico della configurazione vulnerabile.

Tra i problemi più gravi sono emersi un sistema Ubuntu fuori supporto, una password VNC estremamente debole, la vulnerabilità Ghostcat su AJP, protocolli SSL obsoleti, materiale crittografico generato con una vecchia versione Debian/OpenSSL e una bind shell root accessibile senza autenticazione. Le vulnerabilità High hanno inoltre mostrato la presenza di Samba legacy, protocolli rlogin/rsh e una configurazione NFS eccessivamente permissiva.

La parte più importante del lavoro è stata distinguere ciò che veniva realmente dimostrato dai singoli strumenti. Per esempio Nmap può confermare che un servizio è esposto, ma non sempre prova la vulnerabilità specifica indicata da Nessus. Per questo nel documento ho mantenuto separate le evidenze: il Plugin Output di Nessus per il finding e la verifica manuale per il servizio o la configurazione osservabile. Tutte le prove sono state svolte esclusivamente sulle macchine virtuali del laboratorio.